

Standardowa Procedura Operacyjna: Zarządzanie Incydentami Bezpieczeństwa (SOP-SEC-09)

1. Klasyfikacja Incydentów Cybernetycznych

Zgodnie z wymogami Dyrektywy NIS2 oraz art. 33 RODO, każdy pracownik mający podejrzenie naruszenia poufności danych zobowiązany jest do natychmiastowego zgłoszenia incydentu do Zespołu CERT (cert@novapay.example.com lub tel. 555-091-222).

Tabela Poziomów Eskalacji i Czasów Reakcji

Poziom Krytyczności	Opis zagrożenia	Czas reakcji CERT	Powiadomienie Prezesa UODO
KRYTYCZNY (P1)	Wyciek niezaszyfrowanych numerów kart płatniczych / PAN	Maksymalnie 15 minut	W ciągu 24 godzin
WYSOKI (P2)	Nieautoryzowany dostęp do panelu administracyjnego	Maksymalnie 45 minut	W ciągu 72 godzin (jeśli ryzyko)
ŚREDNI (P3)	Infekcja stacji roboczej malwarem bez eksfiltracji danych	Do 4 godzin	Nie dotyczy / Raport wewnętrzny
NISKI (P4)	Podejrzany e-mail phishingowy zablokowany przez filtr	Do 24 godzin	Nie dotyczy

Kopie zapasowe baz transakcyjnych podlegają szyfrowaniu AES-256-GCM. Klucze szyfrujące rotowane są w cyklu 90-dniowym z wykorzystaniem modułu Thales Luna HSM.